Quiz — Security notes

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

Complete after the module reading. Check the separate answer key only after you attempt every item.

1. Why: Why map findings to mitigations you can show in-repo instead of collecting unrelated CVE screenshots?

2. How / ethics: Is scanning a production customer mailbox in scope for this module? What boundary replaces it?

3. Scenario: An API endpoint returns another tenant’s held messages when you change an id. Which class of issue is this, and **what** MailGuard-style mitigation would you implement first?

4. Spot the bug: A lab note says “hacked the server” with no category, no mitigation, and a public target URL. What is missing and **why** each gap matters?

5. Trade-off: Why is broken access control often higher priority than a cosmetic XSS on an internal hold-queue tool?

6. How: Name two OWASP Top 10 categories relevant to a rules API and, for each, one concrete abuse story.